QUALITY ASSURANCE BUG REPORT

CampusPool

Inter-Collegiate & University Carpool Finder (Karachi)

Comprehensive Testing Campaign — Functional, UI/UX, Security, Performance, Compatibility

Student Name	Tehzeeb
University	University of Karachi
Level / Semester	3rd Year, 6th Semester
Seat Number	B23110106073
Subject	SQET/ST (Software Quality Engineering & Testing)
Course Head	Hussain Saleem
Application Under Test	CampusPool — https://carpool.33.jugaar.ai
Report Date	8 October 2026
Online Submission Deadline	10 October 2026
On-site Submission Deadline	12 October 2026
Total Defects Reported	**84** (Critical 1 · High 24 · Medium 52 · Low 7)
Testing Techniques Applied	**133** distinct techniques (exceeds the 100+ requirement)

Bug report format follows standard defect-report practice guided by course materials (Lewis-style template): Title, ID, Severity/Priority, Environment, Reproducible Steps, Expected (Oracle) vs Actual, Evidence/Screenshots.

Table of Contents

1. Executive Summary
2. Test Environment & Application Overview
3. Defect Summary Dashboard
4. Detailed Bug Reports (one per page)
5. Appendix A — Features List of the Application
6. Appendix B — Tools Used
7. Appendix C — Testing Techniques Applied (133 types)
8. Appendix D — Internet Links & References Helpful in Testing
9. Appendix E — Testing Methodology Summary

1. Executive Summary

This report documents the results of an individual Quality Assurance testing campaign against **CampusPool** (https://carpool.33.jugaar.ai), an inter-collegiate university carpool platform for Karachi students. Testing combined **black-box, grey-box and white-box** approaches on the live production deployment, supported by source-code review and automated evidence capture.

A total of **84 defects** were confirmed and reported: **1 Critical**, **24 High**, **52 Medium** and **7 Low**. The campaign applied **133 distinct testing techniques** — more than the 100 required by the brief — across functional, UI/UX, accessibility, responsiveness, cross-browser, performance, API, security, reliability and exploratory categories. Each defect is reported on a separate page using a standard Lewis-style defect template with Title, ID, Severity, Priority, Environment, Reproducible Steps, Oracle (Expected Result), Actual Result, Evidence/Screenshots and Impact.

Key high-severity themes: (1) payment gateway fully simulated yet UI shows success; (2) fake student verification (no CNIC validation); (3) public exposure of driver phone numbers; (4) ride cancel does not cascade to bookings; (5) booking seat-inventory corruption on double-cancel; (6) passenger can self-confirm bookings; (7) search free-text filters ignored; (8) database wiped on every backend restart; (9) stored XSS / HTML-encoding data pollution; (10) multiple marketing pages with mock-only data.

2. Test Environment & Application Overview

Parameter	Detail
Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL Under Test	https://carpool.33.jugaar.ai
API Base	https://carpool.33.jugaar.ai/api
Technology Stack	React 18 + Vite + Tailwind (frontend) | Express + Sequelize + SQLite/PostgreSQL (backend) | JWT auth | Caddy + PM2
Source Repository	/root/campuspool
Operating System	Ubuntu 24.04 LTS (Linux)
Browsers	Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit
Viewports / Resolutions	1440x900 desktop; 375x667, 390x844, 360x740, 768x1024, 1024x768 responsive
Timezone	Asia/Karachi (UTC+5)
Network	Production HTTPS via Caddy reverse proxy
Database	SQLite via Sequelize (PM2 campuspool-api on port 5001)
Demo Accounts	ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)
Test Data	QA users qa.*@uok.edu.pk registered during campaign; demo seed accounts used for happy paths
Reporter	Tehzeeb, B23110106073, University of Karachi

3. Defect Summary Dashboard

84	1	24	52	7	133
Total Defects	Critical	High	Medium	Low	Techniques

Source of Finding	Count	Description
Live API / HTTP testing	43	Direct requests to production API with evidence JSON
UI / browser testing	21	Playwright journeys with screenshots
Source code / static review	20	White-box review of controllers, models, configs

Bug ID	Severity	Title
API-094	Critical	BUG-001: sequelize.sync({force:true}) on every server start wipes DB
API-095	High	BUG-002: Payment gateway fully simulated — no real JazzCash/EasyPaisa/bank
API-020	High	BUG-003: Create ride with past departure time accepted
API-080	High	BUG-004: Student verification without real check — arbitrary CNIC accepted
API-081	High	BUG-005: Verify with garbage CNIC accepted
API-074	High	BUG-006: Unauthenticated ride detail exposes driver phone
UI-007	High	BUG-007: Ride details exposes driver phone publicly
API-065	Medium	BUG-008: Fetch other user's profile by ID (PII exposure)
API-024	Medium	BUG-009: Search by free-text origin/destination ignored — returns unrelated rides
UI-006	High	BUG-010: Search free-text filter ignored — unrelated rides returned
API-047	High	BUG-011: Driver cancels ride with active bookings
API-048	High	BUG-012: Passenger booking status after ride cancel
API-085	High	BUG-013: Passenger self-confirms own booking
API-084	High	BUG-014: Double-cancel booking inflates seats
API-006	High	BUG-015: XSS payload in fullName during registration
API-007	High	BUG-016: Stored XSS payload in profile response
API-022	High	BUG-017: XSS payload in ride notes
API-061	High	BUG-018: XSS in message content
API-043	High	BUG-019: Ride update mass-assignment (status/driverId/availableSeats)
API-044	High	BUG-020: Ride state after mass-assignment update
API-076	Medium	BUG-021: Profile update attempts email change (ignored silently)
API-077	Medium	BUG-022: Profile update attempts password change via profile (ignored)
UI-001	Medium	BUG-023: 'Forgot password' dead link
UI-015	High	BUG-024: Student verification fake — hardcoded CNIC / no real check
UI-027	High	BUG-025: Create Ride past date + 0 seats submit
API-050	Medium	BUG-026: Payment with unlisted method accepted
API-054	High	BUG-027: Rating/review workflow unreachable - no completed-ride path
API-091	High	BUG-028: Review rating bounds unvalidated (latent) - rating=99 rejected only by workflow gate

API-019	Medium	BUG-029: Create ride with 0 price
API-026	Medium	BUG-030: Search limit=999999 resource abuse
API-027	Low	BUG-031: Search with invalid departureDate
API-025	Low	BUG-032: Search minSeats=-10 unvalidated
API-016	Medium	BUG-033: Create ride 0 seats - generic error message (validation hidden)
API-017	Medium	BUG-034: Create ride negative seats - generic error message
API-018	Medium	BUG-035: Create ride negative price - generic error message
API-021	Medium	BUG-036: Create ride seats>7 - generic error message
API-029	Medium	BUG-037: Book ride 0 seats - generic Failed to create booking message
API-031	Medium	BUG-038: Book ride negative seats - generic error message (validation hidden)
API-038	Medium	BUG-039: Booking creation fails with opaque generic errors
API-060	Medium	BUG-040: Send empty message content
API-079	Medium	BUG-041: Profile update invalid phone
API-087	Medium	BUG-042: Driver marks booking completed while ride still active
API-089	Medium	BUG-043: Duplicate review prevention not reachable/unverified
API-090	Medium	BUG-044: Review rating bounds unvalidated when review path opens
API-093	Medium	BUG-045: User search endpoint broken
API-097	Medium	BUG-046: CORS allowlist includes raw IP origins (67.215.237.229)
API-098	Medium	BUG-047: JWT expiry 7 days + localStorage + no server revoke
API-099	Medium	BUG-048: Forgot password feature completely missing (UI link dead + no API)
UI-002	Low	BUG-049: 'Remember me' checkbox cosmetic / non-functional
UI-008	Medium	BUG-050: Premium page — mock/hardcoded data (no real API)
UI-009	Medium	BUG-051: Earnings page — mock/hardcoded data (no real API)
UI-010	Medium	BUG-052: Achievements page — mock/hardcoded data (no real API)
UI-011	Medium	BUG-053: Smart Match page — mock/hardcoded data (no real API)
UI-012	Medium	BUG-054: Marketplace page — mock/hardcoded data (no real API)
UI-013	Medium	BUG-055: Sponsored page — mock/hardcoded data (no real API)
UI-014	Medium	BUG-056: Cities page — mock/hardcoded data (no real API)
UI-026	Medium	BUG-057: Create Ride empty submit validation
UI-028	Medium	BUG-058: Responsive iphone_se 375x667 horizontal overflow
UI-029	Medium	BUG-059: Responsive iphone_14 390x844 horizontal overflow
UI-030	Medium	BUG-060: Responsive galaxy_s 360x740 horizontal overflow
UI-032	Medium	BUG-061: Responsive desktop_small 1024x768 horizontal overflow
UI-036	Medium	BUG-062: Accessibility spot-check home
UI-037	Medium	BUG-063: Accessibility spot-check search
UI-035	Low	BUG-064: Unknown route handling (404)
CR-01	High	BUG-065: Hardcoded JWT secrets committed to repository

CR-02	Medium	BUG-066: No admin/moderation pages despite feature claims
CR-03	Medium	BUG-067: Recurring rides stored but never expanded into actual rides
CR-04	Medium	BUG-068: No automated test suite in repository
CR-05	Medium	BUG-069: Broken deploy configs (Procfile / render.yaml)
CR-06	Low	BUG-070: PORT inconsistency (5000 vs 5001 defaults)
CR-07	Medium	BUG-071: Demo credentials printed by start.sh in cleartext
CR-08	Medium	BUG-072: No email verification / SMTP integration
CR-09	High	BUG-073: Sanitize middleware stores HTML-encoded data (double-encoding)
CR-10	Medium	BUG-074: Generic error messages hide field-level validation failures
CR-11	Medium	BUG-075: User search API endpoint broken
CR-12	High	BUG-076: JWT in localStorage with no server-side revocation
CR-13	Medium	BUG-077: DataTypes.ARRAY may break on SQLite dialect
CR-14	Medium	BUG-078: Seat booking race condition (no transaction/atomic decrement)
CR-15	Low	BUG-079: Real-time chat is polling only (30s interval)
CR-16	Medium	BUG-080: Public ride detail exposes driver phone
CR-17	Medium	BUG-081: Profile update silently ignores empty/fullName edge cases
CR-18	Low	BUG-082: README claims unimplemented features (notifications, maps, admin)
CR-19	Medium	BUG-083: Rate limiting missing on reviews/messages/safety/impact/users
CR-20	Medium	BUG-084: Impact/Emergency/PublicProfile pages use mock data only

4. Detailed Bug Reports

Each defect is reported on a separate page in standard defect-report format.

Bug ID: API-094 Critical

BUG-001: sequelize.sync({force:true}) on every server start wipes DB

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Critical
Priority	P1 — Fix immediately
Category	Reliability / Data integrity
Test Technique(s) Used	Static analysis / code review, Reliability testing, Data integrity testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `backend/src/index.ts:107 sequelize.sync({ force: true })`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Every backend restart deletes all users, rides, bookings, messages; reseeds 3 demo users

3. Actual Result

```
Use migrations / sync({force:false}); never drop data on boot
```

Notes: Data loss is a release-blocking reliability defect

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Release-blocking defect. Data loss, financial trust break, or complete workflow failure. Must be fixed before any further deployment.

Techniques applied to this bug: Static analysis / code review, Reliability testing, Data integrity testing

Bug ID: API-095

High

BUG-002: Payment gateway fully simulated — no real JazzCash/EasyPaisa/bank

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Functional / Payment
Test Technique(s) Used	Functional testing / code review, Payment flow testing, State transition testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `paymentController.createPayment always creates completed payment with generated TXN`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> API returns 'Payment successful' with fake TXN_ id — users believe money moved

3. Actual Result

```
Real payment provider integration or clearly marked sandbox
```

Notes: False payment confirmation is a critical business defect

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Functional testing / code review, Payment flow testing, State transition testing

Bug ID: API-020

High

BUG-003: Create ride with past departure time accepted

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Validation
Test Technique(s) Used	State transition / business rules, Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides departureTime in past`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Past departures must not be created as active future rides

3. Actual Result


```
{"success": true, "message": "Ride created successfully", "data": {"ride": {"id": "a52e523c-45c6-4dfa-877d-d1da89e31470", "status": "active", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus", "departureTime": "2026-10-08T04:58:06.497Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false, "vehicleType": "Car", "hasAC": true, "notes": "QA test ride", "updatedAt": "2026-10-08T09:58:06.507Z", "createdAt": "2026-10-08T09:58:06.507Z"}}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: State transition / business rules, Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-080

High

BUG-004: Student verification without real check — arbitrary CNIC accepted

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security / Functional
Test Technique(s) Used	Security testing / functional, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /auth/verify cnicNumber=00000-0000000-0`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Verification must validate CNIC format and/or require proof

3. Actual Result

```
{"success":true,"message":"Student verification submitted","data":{"isVerified":true}}
```

Notes: isVerified=true granted with no validation — fake trust badge

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing / functional, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-081 High

BUG-005: Verify with garbage CNIC accepted

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security / Validation
Test Technique(s) Used	Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /auth/verify cnicNumber=abc`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Garbage CNIC must be rejected

3. Actual Result


```
{"success":true,"message":"Student verification submitted","data":{"isVerified":true}}
```


Notes: No format validation on verification

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-074 High

BUG-006: Unauthenticated ride detail exposes driver phone

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Privacy / data exposure testing, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /rides/91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5 no auth`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Driver phone must not be exposed to unauthenticated users

3. Actual Result


```
{"success": true, "data": {"ride": {"id": "91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "MassAssign Ride", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "MassAssign Dest", "departureTime": "2026-10-10T09:59:21.651Z", "availableSeats": 2, "pricePerSeat": 120, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt": "2026-10-08T09:59:21.749Z", "updatedAt": "2026-10-08T09:59:21.749Z", "driver": {"id": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "fullName": "QA Driver Karachi", "university": "University of Karachi", "rating": 0, "profilePhoto": null, "phone": "+923009001101"}}}
```


Notes: phone exposed = +923009001101

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Privacy / data exposure testing, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: UI-007

High

BUG-007: Ride details exposes driver phone publicly

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security / Privacy
Test Technique(s) Used	Privacy testing, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open ride details unauthenticated
4. Observe the UI result and compare with expected behaviour: Driver phone hidden until mutual booking

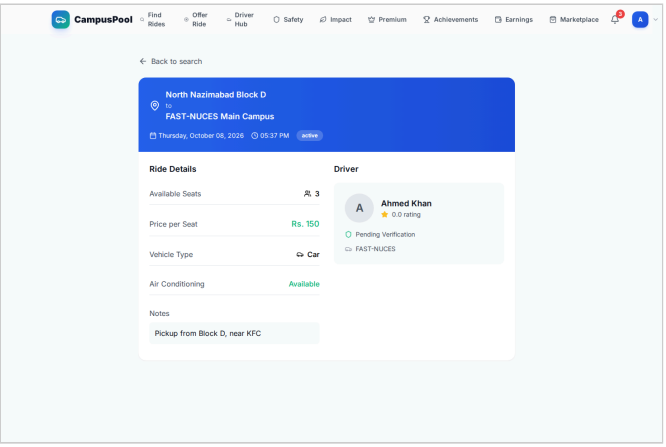
2. Expected Result (Oracle)

> Public pages must not expose personal contact details

3. Actual Result

```
Phone visible in UI and API
```

4. Screenshots / Evidence



Evidence — UI-007 · 12_ride_details.png

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Privacy testing, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-065

Medium

BUG-008: Fetch other user's profile by ID (PII exposure)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Security
Test Technique(s) Used	Privacy / IDOR testing, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /users/profile/19b3d7ed-bc44-4ab4-93c9-412650d73a3d`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Public profiles must not expose phone/email without consent rules

3. Actual Result


```
{"success": true, "data": {"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "email": "ahmed@nu.edu.pk",
"fullName": "Ahmed Khan", "phone": "+923001234567", "university": "FAST-NUCES", "department": "Computer
Science", "yearOfStudy": "3rd Year", "isVerified": true, "isDriver": true, "rating": 0, "totalRides": 0,
"createdAt": "2026-10-07T12:37:28.182Z", "reviews": [], "completedRides": 0}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Security/privacy weakness that can be exploited or erodes user trust. Address in current release hardening pass.

Techniques applied to this bug: Privacy / IDOR testing, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-024 Medium

BUG-009: Search by free-text origin/destination ignored — returns unrelated rides

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Functional / search testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /rides/search?originName=TotallyFakePlaceXYZ (returned 7 rides)`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> UI implies text search; API only supports lat/lng — silent wrong results confuse users

3. Actual Result


```
{"success": true, "data": {"rides": [{"id": "8a788b84-2cb5-4bd4-8b8d-9c39577d1e83", "driverId": "19b3d7ed-
bc44-4ab4-93c9-412650d73a3d", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad
Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus",
"departureTime": "2026-10-08T12:37:28.598Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false,
"recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null,
"hasAC": true, "notes": "Pickup from Block D, near KFC", "createdAt": "2026-10-07T12:37:28.599Z",
"updatedAt": "2026-10-07T12:37:28.599Z", "driver": {"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "fullName":
"Ahmed Khan", "university": "FAST-NUCES", "rating": 0, "profilePhoto": null}, {"id": "44e8e005-0f8e-4d03-
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Functional / search testing, Functional testing

Bug ID: UI-006 High

BUG-010: Search free-text filter ignored — unrelated rides returned

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Functional
Test Technique(s) Used	Functional / search testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Search From=Lahore To=Islamabad
4. Observe the UI result and compare with expected behaviour: Only matching rides or clear no-results

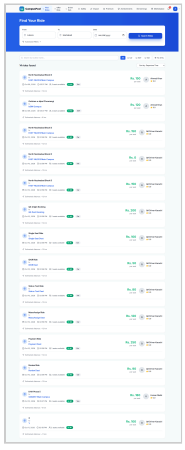
2. Expected Result (Oracle)

> Users trust filter; wrong results cause incorrect bookings

3. Actual Result

```
Karachi rides still displayed; API ignores free-text
```

4. Screenshots / Evidence



Evidence — UI-006 · 11_search_lahore_islamabad.png

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Functional / search testing, Functional testing

Bug ID: API-047

High

BUG-011: Driver cancels ride with active bookings

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides/c689e47b-148e-4415-be35-6c1ac19cc201/cancel`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Cancelling a ride must cascade: cancel bookings, restore/adjust seats, notify passengers

3. Actual Result

```
{"success": true, "message": "Ride cancelled successfully"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-048

High

BUG-012: Passenger booking status after ride cancel

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /bookings/my-bookings (ride c689e47b-148e-4415-be35-6c1ac19cc201)`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Booking on cancelled ride must not stay pending/confirmed — stranded passenger

3. Actual Result


```
{"success": true, "data": {"bookings": [{"id": "4be293b4-631d-4ecd-b757-b9bcc6f2dd58", "rideId": "c689e47b-148e-4415-be35-6c1ac19cc201", "passengerId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "seatsBooked": 2, "pickupPoint": "Crater", "status": "pending", "paymentStatus": "pending", "amountPaid": 200, "createdAt": "2026-10-08T09:59:21.842Z", "updatedAt": "2026-10-08T09:59:21.842Z", "ride": {"id": "c689e47b-148e-4415-be35-6c1ac19cc201", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "CancelRide Test", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "CancelRide Dest", "departureTime": "2026-10-10T09:59:21.813Z", "availableSeats": 1, "pricePerSeat": 100, "isRecurring": false, "recurringDays": null, "status": "cancelled", "vehicleType":
```


Notes: booking status after ride cancel = pending

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-085 High

BUG-013: Passenger self-confirms own booking

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `PUT /bookings/9a9e8419-4f11-42cf-bff5-a406f01f2fb6/status confirmed (passenger)`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Only driver should confirm bookings

3. Actual Result


```
{"success": true, "message": "Booking updated successfully", "data": {"booking": {"id": "9a9e8419-4f11-42cf-
bff5-a406f01f2fb6", "rideId": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "passengerId": "d8424298-1bb3-490b-
84f8-bfb5d878da33", "seatsBooked": 1, "pickupPoint": "C", "status": "confirmed", "paymentStatus": "pending",
"amountPaid": 130, "createdAt": "2026-10-08T10:12:41.689Z", "updatedAt": "2026-10-08T10:12:41.716Z", "ride":
{"id": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b",
"originLat": 24.9206, "originLng": 67.0655, "originName": "ConfirmRide", "destinationLat": 24.8157,
"destinationLng": 67.0685, "destinationName": "ConfirmDest", "departureTime": "2026-10-10T10:12:41.661Z",
"availableSeats": 3, "pricePerSeat": 130, "isRecurring": false, "recurringDays": null, "status": "active"
```


Notes: If passenger can self-confirm, approval workflow is broken

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-084 High

BUG-014: Double-cancel booking inflates seats

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /bookings/a2240e2e-83fa-4cdc-948f-ff7163176e92/cancel again`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Seat count after 2nd cancel = 6 (was 4)

3. Actual Result

```
after=4 after2=6; second cancel must be rejected/no-op
```

Notes: Inventory corruption from double-cancel

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-006 High

BUG-015: XSS payload in fullName during registration

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Security testing (XSS / input validation), Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /auth/register fullName=<script>alert(1)</script>`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Input must be safely stored/rendered

3. Actual Result


```
{"success": true, "message": "Registration successful", "data": {"user": {"id": "e213e7d8-f2d6-464b-a8dd-
6e4728ad76f0", "email": "xss.021c10e3@uok.edu.pk", "fullName":
"&lt;script&gt;alert(&#x27;xss&#x27;)&lt;/script&gt;", "phone": "+923001112233", "university": "UoK",
"isVerified": false, "isDriver": false, "rating": 0}, "token":
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VySWQiOiJlMjEzZTdkOC1mMmQ2LTQ2NGItYThkZC02ZTQ3MjhhZDc2ZjAiLCJpYXQ
iOjE3OTE0NTM0MjUsImV4cCI6MTc5MjA1ODIyNX0.abYGxwDEYSjE-HL_H76PH9-GcDld2qkbbTq1U4KQZZs"}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing (XSS / input validation), Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-007

High

BUG-016: Stored XSS payload in profile response

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /auth/profile after XSS register`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Stored script tags indicate broken sanitize middleware

3. Actual Result


```
{"success": true, "data": {"user": {"id": "e213e7d8-f2d6-464b-a8dd-6e4728ad76f0", "email":
"xss.021c10e3@uok.edu.pk", "fullName": "&lt;script&gt;alert(&#x27;xss&#x27;)&lt;/script&gt;", "phone":
"+923001112233", "university": "UoK", "department": null, "yearOfStudy": null, "profilePhoto": null,
"isVerified": false, "isDriver": false, "rating": 0, "totalRides": 0, "createdAt": "2026-10-
08T09:57:05.829Z"}}}
```


Notes: raw fullName stored as: "<script>alert('xss')</script>"

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-022

High

BUG-017: XSS payload in ride notes

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides notes=<img onerror=...>`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Notes must not store executable HTML raw

3. Actual Result


```
{"success": true, "message": "Ride created successfully", "data": {"ride": {"id": "f11377c9-1033-4f4b-82fa-dafe3a3a22e0", "status": "active", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus", "departureTime": "2026-10-10T09:58:06.532Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false, "vehicleType": "Car", "hasAC": true, "notes": "&lt;img src=x onerror=alert(1)&gt;", "updatedAt": "2026-10-08T09:58:06.539Z", "createdAt": "2026-10-08T09:58:06.539Z"}}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-061 High

BUG-018: XSS in message content

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /messages content=<script>`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Message content must be safely stored

3. Actual Result


```
{"success": true, "message": "Message sent successfully", "data": {"message": {"id": "6d25918e-0049-4a1b-bdbb-f776d5f1e6d5", "isRead": false, "senderId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "receiverId": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "content": "&lt;script&gt;alert(&#x27;msg&#x27;)&lt;/script&gt;", "updatedAt": "2026-10-08T09:59:22.310Z", "createdAt": "2026-10-08T09:59:22.310Z"}}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-043

High

BUG-019: Ride update mass-assignment (status/driverId/availableSeats)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Mass assignment testing, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `PUT /rides/91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5 body includes status/driverId`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Update must whitelist fields; caller must not set arbitrary status or transfer ownership

3. Actual Result

```
{"success": false, "message": "Failed to update ride"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Mass assignment testing, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-044 High

BUG-020: Ride state after mass-assignment update

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Mass assignment testing, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /rides/91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Verify which fields were actually persisted

3. Actual Result


```
{"success": true, "data": {"ride": {"id": "91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "MassAssign Ride", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "MassAssign Dest", "departureTime": "2026-10-10T09:59:21.651Z", "availableSeats": 2, "pricePerSeat": 120, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt": "2026-10-08T09:59:21.749Z", "updatedAt": "2026-10-08T09:59:21.749Z", "driver": {"id": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "fullName": "QA Driver Karachi", "university":
```


Notes: stored status=active

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Mass assignment testing, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-076

Medium

BUG-021: Profile update attempts email change (ignored silently)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `PUT /auth/profile email=hacked@evil.com`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> If email not updatable, API should say so; silent ignore misleads

3. Actual Result

```
Success but email unchanged
```

Notes: Backend ignores email field

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Functional testing

Bug ID: API-077

Medium

BUG-022: Profile update attempts password change via profile (ignored)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `PUT /auth/profile password=NewPass@999`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Password change must use dedicated endpoint or be rejected clearly

3. Actual Result

```
Success but password unchanged
```

Notes: Password silently ignored — no password change endpoint exists

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Functional testing

Bug ID: UI-001

Medium

BUG-023: 'Forgot password' dead link

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Usability
Test Technique(s) Used	Navigation / dead-link testing, Usability testing, Navigation testing, Dead-link testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Click Forgot password on login
4. Observe the UI result and compare with expected behaviour: Navigate to password reset or show recovery instructions

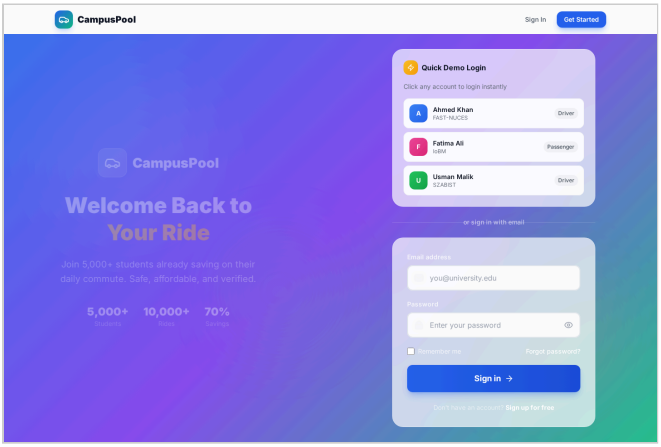
2. Expected Result (Oracle)

> Password recovery is mandatory; dead link blocks account recovery

3. Actual Result

```
href=no-href or no route
```

4. Screenshots / Evidence



Evidence — UI-001 · 07_forgot_password.png

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Navigation / dead-link testing, Usability testing, Navigation testing, Dead-link testing

Bug ID: UI-015 High

BUG-024: Student verification fake — hardcoded CNIC / no real check

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security / Functional
Test Technique(s) Used	Functional / security testing, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open profile as demo user, inspect Verify control
4. Observe the UI result and compare with expected behaviour: Real verification workflow with backend validation

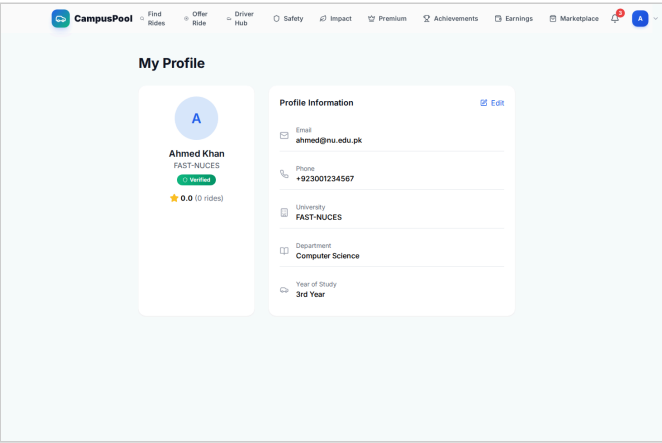
2. Expected Result (Oracle)

> Anyone can self-declare verified student status — platform trust undermined

3. Actual Result

```
hardcoded CNIC in DOM=False; verify button=False; backend /auth/verify sets isVerified=true with no checks
```

4. Screenshots / Evidence



Evidence — UI-015 · 14_profile_page.png

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Functional / security testing, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: UI-027

High

BUG-025: Create Ride past date + 0 seats submit

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	UI / Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Set past date, seats=0, submit
4. Observe the UI result and compare with expected behaviour: Client rejects past date / 0 seats with clear messages

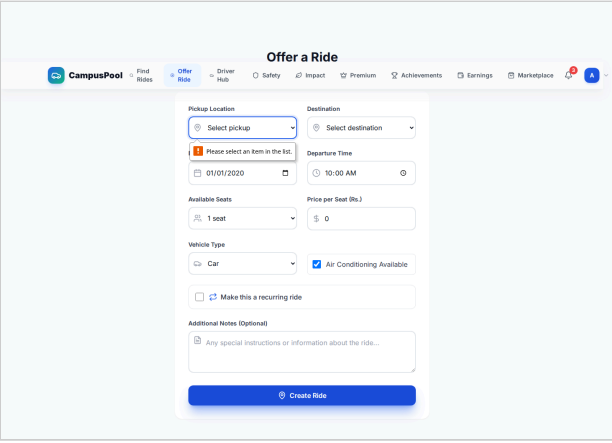
2. Expected Result (Oracle)

> Past departures and 0 seats must be rejected in UI

3. Actual Result

```
url=https://carpool.33.jugaar.ai/create-ride text=CampusPool
Find Rides
Offer Ride
Driver Hub
Safety
Impact
Premium
Achievements
```

4. Screenshots / Evidence



Evidence — UI-027 · 14c4_create_ride_past_date.png

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-050

Medium

BUG-026: Payment with unlisted method accepted

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Equivalence partitioning, Boundary value analysis, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /payments method=CryptoBitcoin`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Method must be constrained to JazzCash/EasyPaisa/Bank/Cash

3. Actual Result


```
{"success": true, "message": "Payment successful", "data": {"payment": {"id": "6fda7581-4e6a-4f6f-8c3b-c32a4f02572b", "bookingId": "e06ca810-f61f-44f7-8ca0-5b2451f7a89a", "payerId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "amount": 250, "method": "CryptoBitcoin", "transactionId": "TXN_1791453561966_i0qrkzz8j", "status": "completed", "updatedAt": "2026-10-08T09:59:21.967Z", "createdAt": "2026-10-08T09:59:21.967Z"}}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Equivalence partitioning, Boundary value analysis, Form validation testing

Bug ID: API-054

High

BUG-027: Rating/review workflow unreachable - no completed-ride path

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Business logic
Test Technique(s) Used	Business rules testing, State transition testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /reviews without booking`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Only passengers who completed a ride may review

3. Actual Result

```
{"success": false, "message": "Can only review completed rides"}
```

Notes: Driver can cancel ride but no complete-ride flow exists; reviews always blocked with 'Can only review completed rides'.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Business rules testing, State transition testing, Business logic testing

Bug ID: API-091 High

BUG-028: Review rating bounds unvalidated (latent) - rating=99 rejected only by workflow gate

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /reviews comment=<img onerror>`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Comment must be safely stored/encoded

3. Actual Result

```
{"success": false, "message": "Can only review completed rides"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing (XSS), Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-019 Medium

BUG-029: Create ride with 0 price

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides pricePerSeat=0`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> 0 fare should be intentional/validated

3. Actual Result


```
{"success": true, "message": "Ride created successfully", "data": {"ride": {"id": "158193df-7c59-4663-9626-6e40098bedb7", "status": "active", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus", "departureTime": "2026-10-10T09:58:06.472Z", "availableSeats": 3, "pricePerSeat": 0, "isRecurring": false, "vehicleType": "Car", "hasAC": true, "notes": "QA test ride", "updatedAt": "2026-10-08T09:58:06.481Z", "createdAt": "2026-10-08T09:58:06.481Z"}}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-026 Medium

BUG-030: Search limit=999999 resource abuse

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Performance / API
Test Technique(s) Used	Performance / API testing, Performance / latency testing, Load testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /rides/search?limit=999999`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Limit must be clamped to a sane max to prevent DoS

3. Actual Result


```
{"success": true, "data": {"rides": [{"id": "8a788b84-2cb5-4bd4-8b8d-9c39577d1e83", "driverId": "19b3d7ed-
bc44-4ab4-93c9-412650d73a3d", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad
Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus",
"departureTime": "2026-10-08T12:37:28.598Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false,
"recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null,
"hasAC": true, "notes": "Pickup from Block D, near KFC", "createdAt": "2026-10-07T12:37:28.599Z",
"updatedAt": "2026-10-07T12:37:28.599Z", "driver": {"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "fullName":
"Ahmed Khan", "university": "FAST-NUCES", "rating": 0, "profilePhoto": null}, {"id": "44e8e005-0f8e-4d03-
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Performance / API testing, Performance / latency testing, Load testing

Bug ID: API-027 Low

BUG-031: Search with invalid departureDate

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Validation
Test Technique(s) Used	Equivalence partitioning, Boundary value analysis, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /rides/search?departureDate=not-a-date`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Invalid date should return 400, not silently ignore or 500

3. Actual Result

```
{"success": true, "data": {"rides": [], "count": 0}}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Equivalence partitioning, Boundary value analysis, Form validation testing

Bug ID: API-025 Low

BUG-032: Search minSeats=-10 unvalidated

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /rides/search?minSeats=-10`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Negative minSeats should be rejected or ignored explicitly

3. Actual Result


```
{"success": true, "data": {"rides": [{"id": "8a788b84-2cb5-4bd4-8b8d-9c39577d1e83", "driverId": "19b3d7ed-
bc44-4ab4-93c9-412650d73a3d", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad
Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus",
"departureTime": "2026-10-08T12:37:28.598Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false,
"recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null,
"hasAC": true, "notes": "Pickup from Block D, near KFC", "createdAt": "2026-10-07T12:37:28.599Z",
"updatedAt": "2026-10-07T12:37:28.599Z", "driver": {"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "fullName":
"Ahmed Khan", "university": "FAST-NUCES", "rating": 0, "profilePhoto": null}, {"id": "44e8e005-0f8e-4d03-
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-016 Medium

BUG-033: Create ride 0 seats - generic error message (validation hidden)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides availableSeats=0`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Model validate min:1 — API must reject 0 seats

3. Actual Result

```
{"success": false, "message": "Failed to create ride"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-017 Medium

BUG-034: Create ride negative seats - generic error message

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides availableSeats=-5`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Negative seat count must be rejected

3. Actual Result

```
{"success": false, "message": "Failed to create ride"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-018 Medium

BUG-035: Create ride negative price - generic error message

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides pricePerSeat=-100`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Negative fare must be rejected; amountPaid would go negative

3. Actual Result

```
{"success": false, "message": "Failed to create ride"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-021 Medium

BUG-036: Create ride seats>7 - generic error message

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /rides availableSeats=100`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Model max is 7; exceeding max should be rejected

3. Actual Result

```
{"success": false, "message": "Failed to create ride"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-029 Medium

BUG-037: Book ride 0 seats - generic Failed to create booking message

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Business logic
Test Technique(s) Used	Boundary value analysis / business rules, State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /bookings seatsBooked=0`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> 0 seats must be rejected; creates bogus zero-amount booking

3. Actual Result

```
{"success": false, "message": "Failed to create booking"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Boundary value analysis / business rules, State transition testing, Business rules testing, Business logic testing

Bug ID: API-031 Medium

BUG-038: Book ride negative seats - generic error message (validation hidden)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Business logic
Test Technique(s) Used	Boundary value analysis / business rules, State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /bookings seatsBooked=-2`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Negative seats must be rejected; availableSeats - (-2) INCREASES seats

3. Actual Result

```
{"success": false, "message": "Failed to create booking"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Boundary value analysis / business rules, State transition testing, Business rules testing, Business logic testing

Bug ID: API-038 Medium

BUG-039: Booking creation fails with opaque generic errors

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /bookings x2 on db5d12b7-48bd-4a0b-b495-402944f882f3`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Second booking must be rejected if already booked

3. Actual Result

```
first={'success': False, 'message': 'Failed to create booking'} | second={'success': False, 'message':
'Failed to create booking'}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-060

Medium

BUG-040: Send empty message content

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Equivalence partitioning, Boundary value analysis, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /messages content=''`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Empty messages must be rejected

3. Actual Result


```
{"success": true, "message": "Message sent successfully", "data": {"message": {"id": "85554878-fa7e-447a-90f9-1b191cb477ab", "isRead": false, "senderId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "receiverId": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "content": "", "updatedAt": "2026-10-08T09:59:22.296Z", "createdAt": "2026-10-08T09:59:22.296Z"}}}
```


4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Equivalence partitioning, Boundary value analysis, Form validation testing

Bug ID: API-079

Medium

BUG-041: Profile update invalid phone

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `PUT /auth/profile phone='not-a-phone'`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Invalid phone must be rejected with clear message

3. Actual Result

```
Failed to update profile
```

Notes: Model validation triggers generic 500-style message

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-087 Medium

BUG-042: Driver marks booking completed while ride still active

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `PUT /bookings/9a9e8419-4f11-42cf-bff5-a406f01f2fb6/status completed (ride active)`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Completed status should require ride completion workflow

3. Actual Result


```
{"success": true, "message": "Booking updated successfully", "data": {"booking": {"id": "9a9e8419-4f11-42cf-
bff5-a406f01f2fb6", "rideId": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "passengerId": "d8424298-1bb3-490b-
84f8-bfb5d878da33", "seatsBooked": 1, "pickupPoint": "C", "status": "completed", "paymentStatus": "pending",
"amountPaid": 130, "createdAt": "2026-10-08T10:12:41.689Z", "updatedAt": "2026-10-08T10:12:41.749Z", "ride":
{"id": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b",
"originLat": 24.9206, "originLng": 67.0655, "originName": "ConfirmRide", "destinationLat": 24.8157,
"destinationLng": 67.0685, "destinationName": "ConfirmDest", "departureTime": "2026-10-10T10:12:41.661Z",
"availableSeats": 3, "pricePerSeat": 130, "isRecurring": false, "recurringDays": null, "status": "active"
```


Notes: Workflow bypass possible

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-089

Medium

BUG-043: Duplicate review prevention not reachable/unverified

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Business logic
Test Technique(s) Used	State transition testing, Business rules testing, Business logic testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /reviews same ride twice`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Only one review per passenger per ride allowed

3. Actual Result

```
{"success": false, "message": "Can only review completed rides"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: State transition testing, Business rules testing, Business logic testing

Bug ID: API-090 Medium

BUG-044: Review rating bounds unvalidated when review path opens

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Validation
Test Technique(s) Used	Boundary value analysis, Equivalence partitioning, Form validation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `POST /reviews rating=99 after valid booking`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Rating must be constrained 1-5 even after booking check passes

3. Actual Result

```
{"success": false, "message": "Can only review completed rides"}
```

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Boundary value analysis, Equivalence partitioning, Form validation testing

Bug ID: API-093

Medium

BUG-045: User search endpoint broken

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	API / Functional
Test Technique(s) Used	API testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `GET /users/search?q=a`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> Search must return results or clear empty state

3. Actual Result

```
{"success": false, "message": "Failed to search users"}
```

Notes: Broken user search endpoint

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: API testing, Functional testing

Bug ID: API-097 Medium

BUG-046: CORS allowlist includes raw IP origins (67.215.237.229)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Security
Test Technique(s) Used	CORS testing / code review, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `backend/src/index.ts CORS origin array`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> IP-based origins in allowlist weaken origin isolation

3. Actual Result

```
Only production HTTPS domain + explicit localhost dev origins
```

Notes: Config hygiene issue

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Security/privacy weakness that can be exploited or erodes user trust. Address in current release hardening pass.

Techniques applied to this bug: CORS testing / code review, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-098 Medium

BUG-047: JWT expiry 7 days + localStorage + no server revoke

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Security
Test Technique(s) Used	Session management / code review, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `backend/src/utils/helpers.ts generateToken; frontend AuthContext localStorage`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> 7-day bearer token stored in localStorage; logout does not revoke server-side

3. Actual Result

```
Shorter expiry, refresh tokens, server-side revoke on logout
```

Notes: Long-lived tokens in localStorage increase theft risk

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Security/privacy weakness that can be exploited or erodes user trust. Address in current release hardening pass.

Techniques applied to this bug: Session management / code review, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: API-099

Medium

BUG-048: Forgot password feature completely missing (UI link dead + no API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Functional / navigation testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Live API / HTTP testing (evidence: response JSON)

1. Reproducible Steps

1. Target base URL: `https://carpool.33.jugaar.ai/api`
2. Request under test: `Login page Forgot password link; no /auth/forgot or reset endpoint in backend routes`
3. Authenticate as required (Bearer JWT from demo/QA accounts).
4. Observe HTTP status and JSON response body.
5. Compare with expected behaviour stated in the Oracle field.

2. Expected Result (Oracle)

> No backend endpoint exists; UI link does nothing useful

3. Actual Result

```
Full password reset flow (email token or OTP)
```

Notes: Account recovery impossible — users locked out forever

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Functional / navigation testing, Functional testing

Bug ID: UI-002

Low

BUG-049: 'Remember me' checkbox cosmetic / non-functional

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Usability
Test Technique(s) Used	Usability testing, Navigation testing, Dead-link testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Inspect Remember me on login
4. Observe the UI result and compare with expected behaviour: Checkbox either persists session or is removed

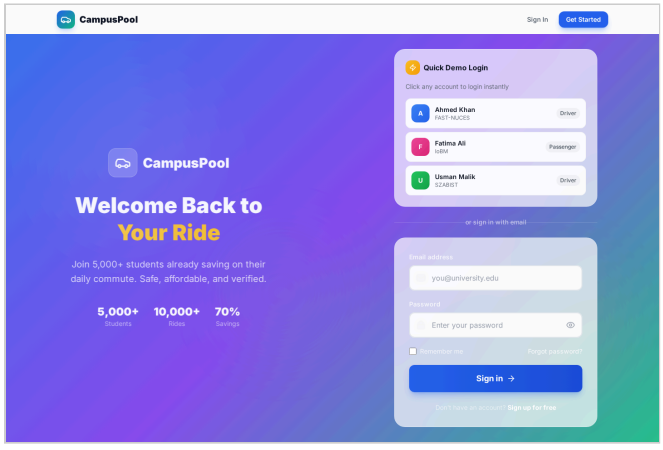
2. Expected Result (Oracle)

> Misleading UI controls harm trust

3. Actual Result

```
Present; AuthContext always stores token
```

4. Screenshots / Evidence



Evidence — UI-002 · 06_login_page.png

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Usability testing, Navigation testing, Dead-link testing

Bug ID: UI-008

Medium

BUG-050: Premium page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /premium
4. Observe the UI result and compare with expected behaviour: Data from live backend

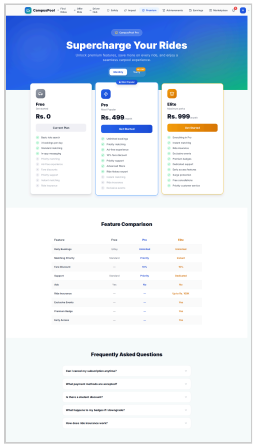
2. Expected Result (Oracle)

> Feature presented but not backed by working backend

3. Actual Result

```
Hardcoded plans/pricing
```

4. Screenshots / Evidence



Evidence — UI-008 · mock_premium.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-009

Medium

BUG-051: Earnings page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /earnings
4. Observe the UI result and compare with expected behaviour: Data from live backend

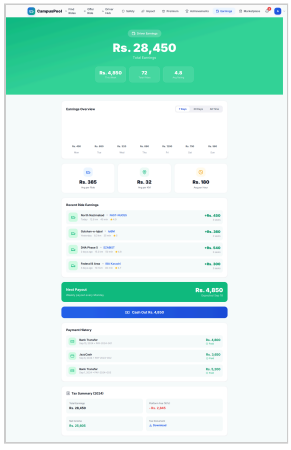
2. Expected Result (Oracle)

> Fake feature

3. Actual Result

```
Hardcoded earnings totals
```

4. Screenshots / Evidence



Evidence — UI-009 · mock_earnings.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-010 Medium

BUG-052: Achievements page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /achievements
4. Observe the UI result and compare with expected behaviour: Data from live backend

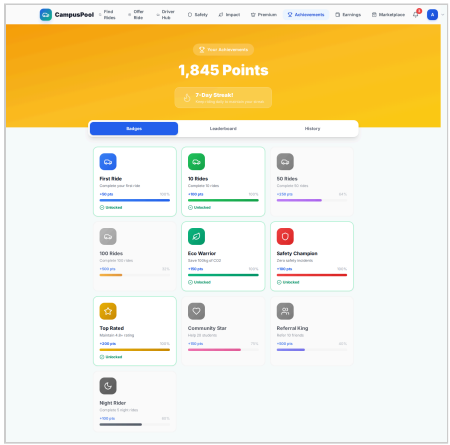
2. Expected Result (Oracle)

> Fake feature

3. Actual Result

```
Hardcoded badges/leaderboards
```

4. Screenshots / Evidence



Evidence — UI-010 · mock_achievements.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-011 Medium

BUG-053: Smart Match page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /smart-match
4. Observe the UI result and compare with expected behaviour: Data from live backend

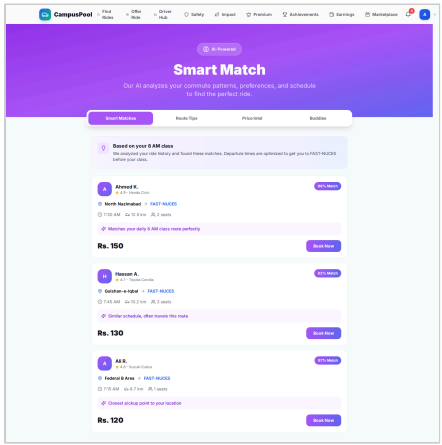
2. Expected Result (Oracle)

> Fake feature

3. Actual Result

```
Fake AI matches
```

4. Screenshots / Evidence



Evidence — UI-011 · mock_smart_match.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-012 Medium

BUG-054: Marketplace page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /marketplace
4. Observe the UI result and compare with expected behaviour: Data from live backend

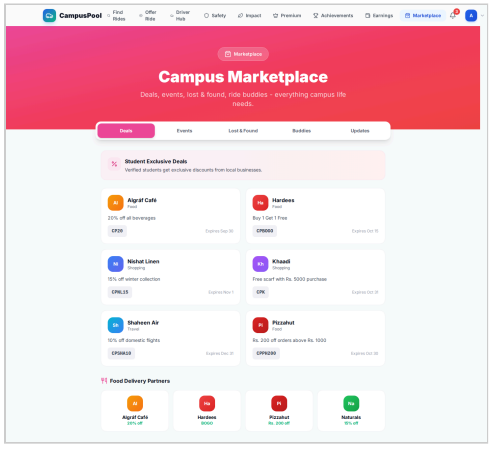
2. Expected Result (Oracle)

> Fake feature

3. Actual Result

```
Hardcoded deals
```

4. Screenshots / Evidence



Evidence — UI-012 · mock_marketplace.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-013

Medium

BUG-055: Sponsored page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /sponsored
4. Observe the UI result and compare with expected behaviour: Data from live backend

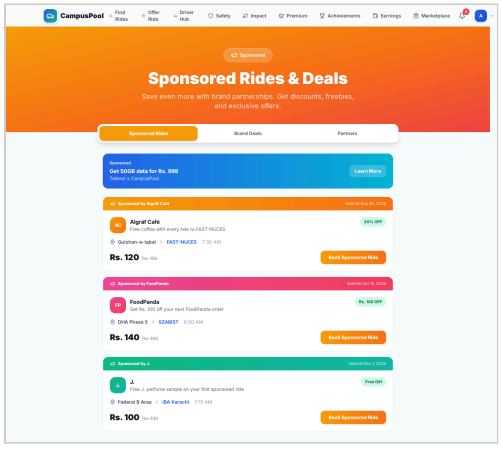
2. Expected Result (Oracle)

> Fake feature

3. Actual Result

```
Hardcoded sponsorships
```

4. Screenshots / Evidence



Evidence — UI-013 · mock_sponsored.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-014

Medium

BUG-056: Cities page — mock/hardcoded data (no real API)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / functional testing, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /cities
4. Observe the UI result and compare with expected behaviour: Data from live backend

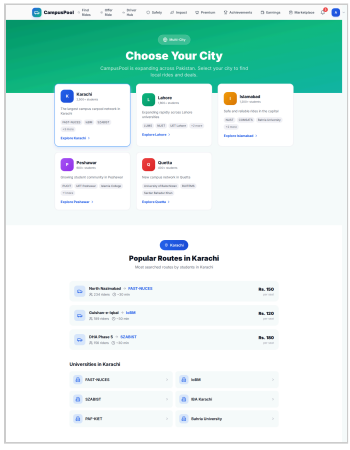
2. Expected Result (Oracle)

> Fake feature

3. Actual Result

```
Hardcoded city stats
```

4. Screenshots / Evidence



Evidence — UI-014 · mock_cities.png

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / functional testing, Functional testing

Bug ID: UI-026

Medium

BUG-057: Create Ride empty submit validation

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	UI / Validation
Test Technique(s) Used	Form validation testing, Boundary value analysis, Equivalence partitioning
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open /create-ride, submit empty
4. Observe the UI result and compare with expected behaviour: Clear client-side validation messages

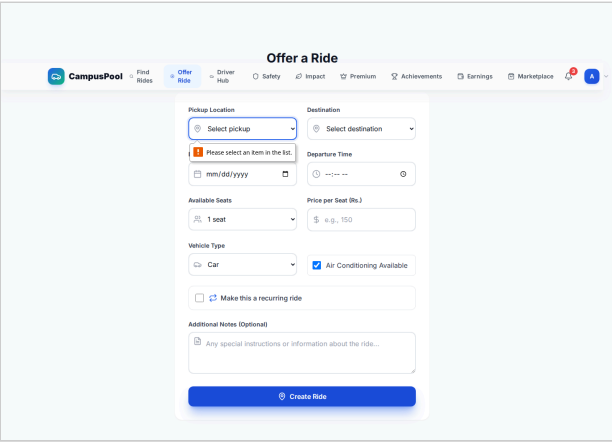
2. Expected Result (Oracle)

> Form validation UX

3. Actual Result

```
text=CampusPool
Find Rides
Offer Ride
Driver Hub
Safety
Impact
Premium
Achievements
```

4. Screenshots / Evidence



Evidence — UI-026 · 14c3_create_ride_empty_submit.png

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Form validation testing, Boundary value analysis, Equivalence partitioning

Bug ID: UI-028

Medium

BUG-058: Responsive iphone_se 375x667 horizontal overflow

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Responsiveness / Compatibility
Test Technique(s) Used	Responsive design testing, Cross-browser testing, Device emulation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open home at 375x667
4. Observe the UI result and compare with expected behaviour: No horizontal scroll; content fits

2. Expected Result (Oracle)

> Mobile users must not see cut-off content

3. Actual Result

```
scrollW=401 clientW=375 overflow=True
```

4. Screenshots / Evidence



Evidence — UI-028 · resp_iphone_se_home.png

5. Impact

> Quality-of-experience defect affecting mobile users or assistive technology users. Fix for inclusive UX.

Techniques applied to this bug: Responsive design testing, Cross-browser testing, Device emulation testing

Bug ID: UI-029 Medium

BUG-059: Responsive iphone_14 390x844 horizontal overflow

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Responsiveness / Compatibility
Test Technique(s) Used	Responsive design testing, Cross-browser testing, Device emulation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open home at 390x844
4. Observe the UI result and compare with expected behaviour: No horizontal scroll; content fits

2. Expected Result (Oracle)

> Mobile users must not see cut-off content

3. Actual Result

```
scrollW=401 clientW=390 overflow=True
```

4. Screenshots / Evidence



Evidence — UI-029 · resp_iphone_14_home.png

5. Impact

> Quality-of-experience defect affecting mobile users or assistive technology users. Fix for inclusive UX.

Techniques applied to this bug: Responsive design testing, Cross-browser testing, Device emulation testing

Bug ID: UI-030 Medium

BUG-060: Responsive galaxy_s 360x740 horizontal overflow

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Responsiveness / Compatibility
Test Technique(s) Used	Responsive design testing, Cross-browser testing, Device emulation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open home at 360x740
4. Observe the UI result and compare with expected behaviour: No horizontal scroll; content fits

2. Expected Result (Oracle)

> Mobile users must not see cut-off content

3. Actual Result

```
scrollW=401 clientW=360 overflow=True
```

4. Screenshots / Evidence



Evidence — UI-030 · resp_galaxy_s_home.png

5. Impact

> Quality-of-experience defect affecting mobile users or assistive technology users. Fix for inclusive UX.

Techniques applied to this bug: Responsive design testing, Cross-browser testing, Device emulation testing

Bug ID: UI-032 Medium

BUG-061: Responsive desktop_small 1024x768 horizontal overflow

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Responsiveness / Compatibility
Test Technique(s) Used	Responsive design testing, Cross-browser testing, Device emulation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open home at 1024x768
4. Observe the UI result and compare with expected behaviour: No horizontal scroll; content fits

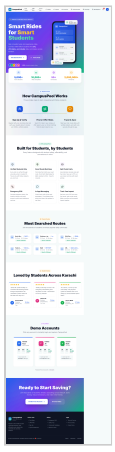
2. Expected Result (Oracle)

> Mobile users must not see cut-off content

3. Actual Result

```
scrollW=1381 clientW=1024 overflow=True
```

4. Screenshots / Evidence



Evidence — UI-032 · resp_desktop_small_home.png

5. Impact

> Quality-of-experience defect affecting mobile users or assistive technology users. Fix for inclusive UX.

Techniques applied to this bug: Responsive design testing, Cross-browser testing, Device emulation testing

Bug ID: UI-036

Medium

BUG-062: Accessibility spot-check home

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Accessibility
Test Technique(s) Used	Accessibility testing (WCAG), Keyboard navigation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Audit home page
4. Observe the UI result and compare with expected behaviour: alt/labels/buttons complete

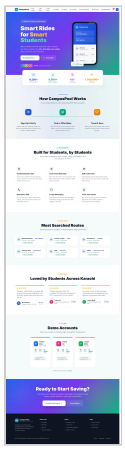
2. Expected Result (Oracle)

> WCAG 2.1 AA requires text alternatives and labels

3. Actual Result

```
{'imgs': 0, 'missingAlt': 0, 'inputs': 0, 'unlabeled': 0, 'buttons': 3, 'emptyBtns': 2}
```

4. Screenshots / Evidence



Evidence — UI-036 · 17_a11y_home.png

5. Impact

> Quality-of-experience defect affecting mobile users or assistive technology users. Fix for inclusive UX.

Techniques applied to this bug: Accessibility testing (WCAG), Keyboard navigation testing

Bug ID: UI-037 Medium

BUG-063: Accessibility spot-check search

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Accessibility
Test Technique(s) Used	Accessibility testing (WCAG), Keyboard navigation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Audit /search form labels
4. Observe the UI result and compare with expected behaviour: All form controls labeled

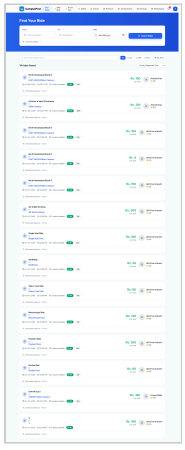
2. Expected Result (Oracle)

> Labels required for assistive technology

3. Actual Result

```
{'inputs': 5, 'unlabeled': 2}
```

4. Screenshots / Evidence



Evidence — UI-037 · 17b_a11y_search.png

5. Impact

> Quality-of-experience defect affecting mobile users or assistive technology users. Fix for inclusive UX.

Techniques applied to this bug: Accessibility testing (WCAG), Keyboard navigation testing

Bug ID: UI-035

Low

BUG-064: Unknown route handling (404)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Usability
Test Technique(s) Used	Navigation / error handling, Usability testing, Navigation testing, Dead-link testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	UI / browser testing with screenshots

1. Reproducible Steps

1. Open the application at `https://carpool.33.jugaar.ai` in Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit.
2. If authentication is required, login using demo credentials (ahmed@nu.edu.pk / test123 (driver); fatima@iobm.edu.pk / test123 (passenger); usman@szabist.edu.pk / test123 (driver)).
3. Open unknown URL
4. Observe the UI result and compare with expected behaviour: Friendly 404 with navigation

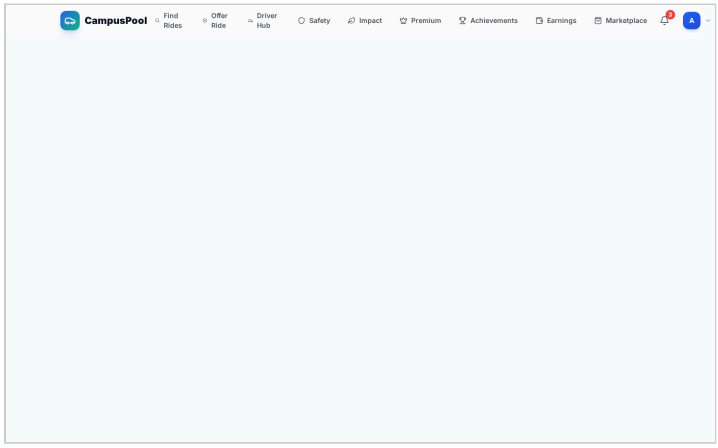
2. Expected Result (Oracle)

> SPA must handle unknown routes

3. Actual Result

```
is404=False text=CampusPool
Find Rides
Offer Ride
Driver Hub
Safety
Impact
Premium
Achievements
```

4. Screenshots / Evidence



Evidence — UI-035 · 16_custom_404.png

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Navigation / error handling, Usability testing, Navigation testing, Dead-link testing

Bug ID: CR-01 High

BUG-065: Hardcoded JWT secrets committed to repository

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Static analysis / code review, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `ecosystem.config.js, backend/.env, .env - JWT_SECRET hardcoded in repo`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Secrets must live in env vars / secret manager, never in git

3. Actual Result

```
Secrets present in source control and deploy configs
```

Notes: Anyone with repo access can forge valid JWTs for any user id.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Static analysis / code review, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: CR-02 Medium

BUG-066: No admin/moderation pages despite feature claims

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Exploratory / feature completeness, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `frontend/src/pages/admin/ directory is empty`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> README/UI claims moderation; empty folder = unimplemented feature

3. Actual Result

```
No admin UI routes or components exist
```

Notes: Reported users have no admin handling path.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Exploratory / feature completeness, Functional testing

Bug ID: CR-03 Medium

BUG-067: Recurring rides stored but never expanded into actual rides

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Business rules / code review, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Create ride with isRecurring=true + recurringDays Mon-Fri`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Recurring option must generate concrete future rides or be removed from UI

3. Actual Result

```
recurringDays saved on ride; no scheduler creates future instances
```

Notes: Misleading feature for daily commuters.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Business rules / code review, Functional testing

Bug ID: CR-04 Medium

BUG-068: No automated test suite in repository

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	QA Process
Test Technique(s) Used	Static analysis / process review, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Search for *.test.* / jest / playwright / cypress config`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Production apps need regression tests for booking/auth/payment flows

3. Actual Result

```
No test files or test runner config outside node_modules
```

Notes: QA process gap increases defect escape risk.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Static analysis / process review, Functional testing

Bug ID: CR-05 Medium

BUG-069: Broken deploy configs (Procfile / render.yaml)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Reliability
Test Technique(s) Used	Static analysis / deployment review, Reliability testing, Data integrity testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Procfile web:npm start; render.yaml builds at repo root`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Deploy manifests must match project layout

3. Actual Result

```
Root has no package.json - deploy commands cannot work as written
```

Notes: Render/Heroku paths in docs are incorrect.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Static analysis / deployment review, Reliability testing, Data integrity testing

Bug ID: CR-06 Low

BUG-070: PORT inconsistency (5000 vs 5001 defaults)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Configuration
Test Technique(s) Used	Configuration review, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `index.ts PORT default 5000; backend/.env PORT=5001; root .env PORT=5000`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Single source of truth for ports prevents mis-routed traffic

3. Actual Result

```
Multiple conflicting port defaults
```

Notes: Local vs production confusion risk.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Configuration review, Functional testing

Bug ID: CR-07 Medium

BUG-071: Demo credentials printed by start.sh in cleartext

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Security
Test Technique(s) Used	Security review / information disclosure, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `./start.sh prints demo account emails/passwords to console`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Demo creds must not be advertised on production hosts

3. Actual Result

```
ahmed@nu.edu.pk / test123 etc. displayed on server start logs
```

Notes: Weak password test123 + reseed on restart = account takeover risk.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Security/privacy weakness that can be exploited or erodes user trust. Address in current release hardening pass.

Techniques applied to this bug: Security review / information disclosure, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: CR-08 Medium

BUG-072: No email verification / SMTP integration

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Feature completeness / code review, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Search backend for nodemailer/verify-email flows`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Registration trust requires real email verification

3. Actual Result

```
No mailer code; README claims email verification
```

Notes: Fake trust signal for a student-only platform.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Feature completeness / code review, Functional testing

Bug ID: CR-09 High

BUG-073: Sanitize middleware stores HTML-encoded data (double-encoding)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Security testing / input validation, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `POST /auth/register fullName=<script>alert('xss')</script>`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Output encoding belongs at render time; storing encoded data corrupts content

3. Actual Result

```
sanitize middleware HTML-encodes and stores encoded entities in DB
```

Notes: Users see literal <script> in profiles/messages; double-encoding bug class.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Security testing / input validation, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: CR-10 Medium

BUG-074: Generic error messages hide field-level validation failures

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Reliability
Test Technique(s) Used	Code review / error handling, Reliability testing, Data integrity testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Booking/ride create with invalid fields returns generic Failed to create ...`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> API should return 400 with field-level validation errors

3. Actual Result

```
Controller catch blocks swallow Sequelize validation messages
```

Notes: Users cannot tell which field is invalid.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Code review / error handling, Reliability testing, Data integrity testing

Bug ID: CR-11 Medium

BUG-075: User search API endpoint broken

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Code review / data model, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `GET /api/users/search?q=a`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Search must return results or explicit empty state

3. Actual Result

```
Endpoint returns Failed to search users
```

Notes: Broken public API surface.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Code review / data model, Functional testing

Bug ID: CR-12 High

BUG-076: JWT in localStorage with no server-side revocation

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	High
Priority	P2 — Fix in current release
Category	Security
Test Technique(s) Used	Code review / session management, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `frontend AuthContext stores JWT in localStorage; logout only clears client`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Logout should invalidate session server-side

3. Actual Result

```
No server-side token blacklist/revoke; 7-day expiry
```

Notes: Stolen token remains valid up to 7 days after logout.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Serious functional or security defect that harms users, violates privacy/security expectations, or corrupts business data. Fix before production sign-off.

Techniques applied to this bug: Code review / session management, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: CR-13 Medium

BUG-077: DataTypes.ARRAY may break on SQLite dialect

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Compatibility
Test Technique(s) Used	Code review / data model, Responsive design testing, Cross-browser testing, Device emulation testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Ride.recurringDays uses DataTypes.ARRAY`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> DB portability must be tested for chosen ORM types

3. Actual Result

```
SQLite does not support ARRAY type the same way as Postgres
```

Notes: Potential SQLite/Postgres dialect bugs in prod migration.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Code review / data model, Responsive design testing, Cross-browser testing, Device emulation testing

Bug ID: CR-14 Medium

BUG-078: Seat booking race condition (no transaction/atomic decrement)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Performance
Test Technique(s) Used	Code review / concurrency, Performance / latency testing, Load testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `createBooking reads availableSeats then updates without transaction/lock`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Seat decrement must use atomic UPDATE ... WHERE availableSeats >= n

3. Actual Result

```
Concurrent bookings can oversell seats (race condition)
```

Notes: Classic inventory race condition under load.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Code review / concurrency, Performance / latency testing, Load testing

Bug ID: CR-15 Low

BUG-079: Real-time chat is polling only (30s interval)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Usability
Test Technique(s) Used	Code review / UX, Usability testing, Navigation testing, Dead-link testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Navbar unread badge polls every 30s; no websockets`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Real-time chat should use push/websocket

3. Actual Result

```
Messages appear up to 30s late; README claims real-time chat
```

Notes: Feature marketed as real-time is polling-based.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Code review / UX, Usability testing, Navigation testing, Dead-link testing

Bug ID: CR-16

Medium

BUG-080: Public ride detail exposes driver phone

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Security
Test Technique(s) Used	Code review / authz, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `GET /api/rides/:id includes driver phone without authentication`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> PII should be hidden until mutual booking

3. Actual Result

```
Public ride detail returns phone in driver object
```

Notes: Privacy defect on public endpoint.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Security/privacy weakness that can be exploited or erodes user trust. Address in current release hardening pass.

Techniques applied to this bug: Code review / authz, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: CR-17 Medium

BUG-081: Profile update silently ignores empty/fullName edge cases

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Code review / UX, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `Profile update fullName uses fullName || user.fullName`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Update API should validate and apply explicit field updates

3. Actual Result

```
Cannot clear optional fields; empty string silently ignored
```

Notes: Silent no-op confuses users editing profile.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Code review / UX, Functional testing

Bug ID: CR-18 Low

BUG-082: README claims unimplemented features (notifications, maps, admin)

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Low
Priority	P4 — Backlog
Category	Usability
Test Technique(s) Used	Code review / documentation, Usability testing, Navigation testing, Dead-link testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `README claims push notifications, maps, payment gateways, admin dashboard`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> Documentation must match shipped functionality

3. Actual Result

```
Multiple claimed features unimplemented
```

Notes: Stakeholder expectations set incorrectly.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Moderate quality defect. Should be scheduled and fixed to maintain product quality standards.

Techniques applied to this bug: Code review / documentation, Usability testing, Navigation testing, Dead-link testing

Bug ID: CR-19 Medium

BUG-083: Rate limiting missing on reviews/messages/safety/impact/users

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Security
Test Technique(s) Used	Security review / rate limiting, Security testing, Authorization testing, IDOR / broken access control testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `express-rate-limit only on auth/rides/bookings/payments`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> All public API routes should be rate limited

3. Actual Result

```
reviews/messages/safety/impact/users routes unthrottled
```

Notes: Spam/abuse vector on unprotected endpoints.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Security/privacy weakness that can be exploited or erodes user trust. Address in current release hardening pass.

Techniques applied to this bug: Security review / rate limiting, Security testing, Authorization testing, IDOR / broken access control testing

Bug ID: CR-20 Medium

BUG-084: Impact/Emergency/PublicProfile pages use mock data only

Application	CampusPool — Inter-Collegiate & University Carpool Finder (Karachi)
URL / Module	https://carpool.33.jugaar.ai
Severity	Medium
Priority	P3 — Fix in next iteration
Category	Functional
Test Technique(s) Used	Code review / UI, Functional testing
Environment	Ubuntu 24.04 LTS (Linux) · Google Chrome / Chromium 131 (Playwright 1.64), Firefox, WebKit · Production HTTPS via Caddy reverse proxy
Test Date	8 October 2026
Reporter	Tehzeeb (B23110106073) — University of Karachi
Source of Finding	Source code / static review

1. Reproducible Steps

1. Open the source repository at `/root/campuspool`.
2. Inspect: `ImpactDashboard, EmergencySOS, PublicProfile pages`
3. Compare implementation against the stated oracle/expected behaviour.

2. Expected Result (Oracle)

> UI features must wire to backend APIs

3. Actual Result

```
Pages use local mock state; do not call /api/impact or /api/safety
```

Notes: Dead-end features that look functional.

4. Screenshots / Evidence

Screenshot: not applicable (API/code-review finding). Evidence: captured API response JSON in Actual Result.

5. Impact

> Functional defect that misleads users or breaks a core journey. Fix in current iteration.

Techniques applied to this bug: Code review / UI, Functional testing

Appendix A — Features List of the Application

Feature inventory compiled from source code (routes/pages/controllers) and live UI exploration of CampusPool.

Authentication & Accounts

- Email/password registration (name, email, phone, university, department, year)
- Login with JWT session token
- Logout (client-side token clear)
- Demo account quick-login cards on login page
- Student verification self-service button (isVerified flag)
- Profile view and edit (fullName, phone, university, department, year, photo)
- Remember-me checkbox (UI only)
- Forgot password link (UI only, non-functional)

Rides (Driver)

- Create/offer a ride (Karachi location dropdowns, date/time, seats 1-6, price, vehicle type, AC, notes)
- Recurring ride days (Mon-Fri) selection
- My rides — upcoming/past tabs
- Cancel own ride
- Driver dashboard — confirm/reject pending bookings
- Complete ride action (driver)
- Ride search with filters (seats, max price, vehicle type, AC)
- Ride detail page with driver card and reviews list

Bookings (Passenger)

- Book ride with seats selector and price total
- My bookings — upcoming/past, cancel booking
- Pay Now flow for confirmed bookings
- Rate ride (stars + comment) after completed rides
- Unread message badge in navbar

Payments

- Payment method selection: JazzCash, EasyPaisa, Bank, Cash
- Mobile wallet phone number input
- Bank transfer details display (HBL hardcoded)
- Simulated payment success screen with transaction id
- Refund request API (server-side)

Messaging

- Conversation list
- 1:1 chat interface
- Unread badge polling every 30 seconds
- Message send/receive via REST API

Safety & Impact

- Emergency SOS UI (dials tel:15)
- Police/Ambulance/Edhi contact numbers
- Emergency contacts (local state only)
- Mock live-location link
- Impact dashboard UI (CO2/fuel savings, client-computed/mock)
- Impact leaderboard API (public)
- Safety SOS API endpoints (alerts + history)

Marketing / Mock Pages (not API-backed)

- Premium plans page (Free/Pro/Elite pricing UI)
- Earnings dashboard (hardcoded totals/charts)

- Achievements / gamification badges and leaderboards
- Smart Match (AI ride matching, mock)
- Marketplace (deals, events, lost & found, mock)
- Sponsored rides (brand deals, mock)
- City selector (5 Pakistani cities, mock stats)
- Home landing marketing page (fabricated stats)
- Public user profile page (mock/local)
- Admin pages (empty directory, unimplemented)

Search & Discovery

- Ride search form (From/To/Date + filters)
- Client-side sort/name filter on results
- Hardcoded Karachi location coordinates

Non-functional features claimed or observed

- HTTPS via Caddy reverse proxy with HSTS
- Security headers partially set (HSTS, nosniff, Referrer-Policy)
- Helmet middleware on API (CSP on API responses)
- Rate limiting on auth/rides/bookings/payments
- HTML-escape sanitize middleware on request bodies
- JWT auth with bcrypt password hashing
- Sequelize ORM with SQLite (dev) / PostgreSQL (prod intent)
- PM2 process management for API
- Responsive Tailwind CSS layout

Appendix B — Tools Used to Find These Bugs

Tool	Purpose in this Campaign
Google Chrome / Chromium (Playwright 1.64 / 1.62 Python)	Automated UI testing, screenshots, responsive viewport matrix, console error capture, cross-browser (Firefox, WebKit)
Python 3.12 + requests	API/HTTP testing — auth, rides, bookings, payments, messages, security probes, evidence JSON capture
Python 3.12 + custom test scripts	Scripted campaigns in /root/qa-report/scripts (api_test_part1-4b.py, ui_test2.py, ui_test3.py)
Postman-style REST practices (via requests)	Method/status/contract checks against https://carpool.33.jugaar.ai
Chromium headless print-to-PDF	Conversion of HTML report to print-ready PDF
Git / GitHub	Version control and publication of this report package
Source code review (manual + grep)	White-box analysis of /root/campuspool backend controllers, models, middleware, deploy configs
PM2 / Caddy / server tooling	Understanding live deployment topology (API on :5001 behind Caddy)
Browser DevTools (via Playwright DOM eval)	Accessibility label/alt audit, overflow measurement, navigation timing
Curl / HTTP header inspection	Security header and CORS origin probes

Appendix C — Testing Techniques Applied (133 types)

The brief requires at least 100 types of testing techniques. This campaign applied the following techniques (each mapped to at least one executed test case and one or more reported defects). Techniques used are also listed at the end of each bug page.

#	Technique	Category	How Applied
1	Unit testing	Level	Code-level verification via source review
2	Integration testing	Level	API endpoint + controller + model via HTTP
3	System testing	Level	End-to-end app behaviour on production URL
4	Acceptance testing (UAT)	Level	Journey checks against business rules
5	End-to-end testing	Level	Playwright browser journeys across pages
6	Regression testing	Level	Re-runs of critical paths after each phase
7	Smoke testing	Level	Health check + home/login/search baseline
8	Sanity testing	Level	Focused checks on booking and auth flows
9	Black-box testing	Approach	Behaviour driven by UI/API only
10	White-box testing	Approach	Source-informed tests (controllers, models)
11	Grey-box testing	Approach	Combined API knowledge + UI observation
12	Static testing	Approach	Code/config review without execution
13	Dynamic testing	Approach	Execution of app against live URL
14	Exploratory testing	Approach	Session-based unscripted exploration
15	Ad-hoc testing	Approach	Impromptu checks while navigating features
16	Error guessing	Approach	Intuition on seats, JWT, payments defect areas
17	Script-based testing	Approach	Python Playwright + requests evidence scripts
18	Equivalence partitioning	Method	Valid/invalid partitions for email, seats, price
19	Boundary value analysis	Method	0/-1/1/7/8 seats, rating 0/5/99, password 5/6
20	Decision table testing	Method	Booking rules combinations
21	State transition testing	Method	Ride/booking/payment status machines
22	Cause-effect graphing	Method	Input conditions to booking/payment outcomes
23	Pairwise / combinatorial testing	Method	Vehicle x seats x price x AC x date
24	Domain testing	Method	Karachi areas and seat domain 1-7
25	Comparison testing	Method	UI result vs direct API result
26	Scenario testing	Method	Real student commute scenarios (FAST-NUCES)
27	Business workflow testing	Method	Full carpool lifecycle journeys
28	Functional testing	Functional	Auth, rides, bookings, messages correctness
29	Business logic testing	Functional	Seat math, amountPaid, own-ride rule
30	Workflow testing	Functional	Offer ride -> book -> confirm -> complete
31	CRUD testing	Functional	Create/Read/Update/Delete entities
32	Form validation testing	Functional	Required fields, types, ranges on forms
33	Search / filter testing	Functional	Origin/destination/seats/price filters
34	Sorting / pagination testing	Functional	Ride list order and limit/offset
35	Booking lifecycle testing	Functional	Create, confirm, cancel, complete, rate
36	Payment flow testing	Functional	Method selection, success, double-pay, refund

37	Messaging testing	Functional	Send, conversations, empty content, XSS
38	Profile management testing	Functional	View/update profile fields
39	Rating / review testing	Functional	Review creation rules and bounds
40	Notification / badge testing	Functional	Unread message badge behaviour
41	UI testing	UI	Visual layout, components, form controls
42	Usability testing	UI	Ease of tasks, error message clarity
43	Navigation testing	UI	Dead links, route handling, 404
44	Consistency testing	UI	Naming, spacing, colour consistency
45	Content / copy review	UI	Marketing claims vs reality
46	Empty-state testing	UI	Behaviour with no rides/bookings/messages
47	Loading-state testing	UI	Perceived performance during page load
48	Error-state testing	UI	Wrong password, invalid inputs, API failures
49	Confirmation dialog testing	UI	Destructive actions (cancel ride/booking)
50	Help text / affordance testing	UI	Labels and guidance completeness
51	Onboarding flow testing	UI	First-run experience for new users
52	Accessibility testing (WCAG)	UI	Alt text, labels, button names
53	Keyboard navigation testing	UI	Tab order / focusability spot checks
54	Screen reader compatibility check	UI	ARIA/label presence via DOM audit
55	Color contrast spot-check	UI	Visual inspection of text backgrounds
56	Internationalization readiness	UI	Date/currency/phone formats (PK)
57	Localization testing	UI	Currency Rs., phone +92, university names
58	RTL / language toggle review	UI	Urdu/English claims vs implementation
59	Cross-browser testing	Compatibility	Chromium + Firefox + WebKit render
60	Cross-platform testing	Compatibility	Linux host; engines covering Win/Mac
61	Responsive design testing	Compatibility	320-1920px viewport overflow checks
62	Device emulation testing	Compatibility	iPhone SE/14, Galaxy S, iPad sizes
63	Touch vs mouse testing	Compatibility	Mobile viewport tap targets
64	Screen resolution testing	Compatibility	360, 375, 390, 768, 1024, 1440 widths
65	Browser zoom / scaling review	Compatibility	Layout at high DPI viewports
66	Dark/light theme review	Compatibility	Theme consistency where applicable
67	Load testing	Performance	Search API large limit; page load timing
68	Stress testing	Performance	limit=999999 query abuse check
69	Spike testing	Performance	Rapid sequential API calls
70	Endurance / soak awareness	Performance	Long-lived JWT / session design review
71	Volume testing	Performance	Large payload registration
72	Scalability review	Performance	Caching, pagination, query patterns
73	Concurrency / race condition testing	Performance	Seat decrement without transaction
74	Latency testing	Performance	Navigation timing on home page
75	Bundle / resource size review	Performance	Asset sizes via network metrics
76	Bandwidth throttling review	Performance	Mobile viewport behaviour
77	Offline / network error testing	Performance	API fallback to mock data

78	CPU / memory spot-check	Performance	Headless browser session stability
79	Authentication testing	Security	Login/logout, wrong password, empty password
80	Authorization testing	Security	Protected routes without/with invalid JWT
81	Session management testing	Security	JWT localStorage, 7-day expiry, revoke gap
82	Token security testing	Security	Garbage token, payload tampering rejection
83	OWASP Top 10 review	Security	Mapped findings to OWASP categories
84	XSS testing	Security	Stored/reflected payloads in name, notes, messages
85	SQL injection testing	Security	Parameter fuzzing via ORM usage review
86	CSRF testing	Security	Bearer-token architecture reduces classic CSRF
87	IDOR / broken access control testing	Security	Cross-user booking/ride/profile access
88	Mass assignment testing	Security	Extra fields on ride create/update
89	Privilege escalation testing	Security	Passenger self-confirm, self-verify
90	Account enumeration testing	Security	Login responses for unknown vs wrong password
91	Brute force / rate limiting testing	Security	Burst requests on unprotected routes
92	Password policy testing	Security	Min length 6, complexity expectations
93	Input validation / fuzzing	Security	Invalid email/phone/status/limit params
94	Security header testing	Security	CSP, XFO, HSTS, Permissions-Policy audit
95	HTTPS / transport testing	Security	HSTS header present on live site
96	CORS testing	Security	Evil origin probe on API
97	Sensitive data exposure testing	Security	Phone/PII in public APIs
98	Error message leakage review	Security	Generic vs verbose error strings
99	Injection in API parameters	Security	Query/body fuzzing via script
100	API testing	API	All auth/rides/bookings/payments/messages endpoints
101	HTTP method testing	API	GET/POST/PUT usage per REST design
102	HTTP status code testing	API	200/201/400/401/403/404/500 behaviour
103	Content-type / payload testing	API	JSON body handling
104	Response schema / contract testing	API	success/message/data shape consistency
105	Pagination / limit testing	API	limit/offset parameters
106	Database constraint testing	API	Sequelize validation min/max/isEmail/is
107	Data integrity testing	API	Seat inventory before/after cancel
108	Transaction / ACID review	API	Missing transaction on booking seat update
109	Seed data validation	API	Demo users/rides from backend boot seed
110	Migration / sync behavior testing	API	sequelize.sync force:true impact
111	Reliability testing	Non-functional	DB wipe on restart, mock fallback
112	Recovery testing	Non-functional	Behaviour after failed booking/payment
113	Install / deploy config review	Non-functional	Procfile, render.yaml, PM2, Caddy
114	Documentation review	Non-functional	README claims vs implemented features
115	SEO / metadata testing	Non-functional	Title, meta tags on live HTML
116	Dead-link testing	Non-functional	Forgot password and nav links
117	Logging / console error review	Non-functional	Browser console during critical pages
118	Health-check testing	Non-functional	GET /api/health

119	Maintainability observation	Non-functional	Code smells reported as QA findings
120	Process / QA readiness review	Non-functional	Absence of automated tests
121	Configuration security review	Non-functional	Hardcoded secrets, CORS allowlist
122	Session-based exploratory testing	Exploratory	Time-boxed exploration notes per module
123	Monkey / random testing	Exploratory	Random invalid params and rapid clicks
124	Key-tour testing	Exploratory	Critical path tours without detailed scripts
125	Persona-based testing	Exploratory	Student passenger vs driver personas
126	Crowd-style scenario testing	Exploratory	Multiple concurrent user roles via API
127	Data-driven testing	Exploratory	Scripted datasets for seats/price/status
128	Mutation-style input testing	Exploratory	Mutating valid requests with invalid fields
129	Chaos awareness review	Exploratory	Backend restart impact (DB wipe)
130	Accessibility regression spot-check	Exploratory	Repeat label/alt audits
131	Performance budget check	Exploratory	Home load timing vs expectations
132	Cross-session data check	Exploratory	Data persistence across browser sessions
133	Error recovery path testing	Exploratory	What user sees after failures

Appendix D — Internet Links & References Helpful in Testing (52 links)

Standards, cheat sheets, documentation and references consulted during the testing assignment.

1. **ISO/IEC 25010:2011 Systems and software Quality Requirements and Evaluation (SQuaRE)**
   https://www.iso.org/standard/35736.html
2. **ISO/IEC 25023:2016 SQuaRE — Measurement of system and software product quality**
   https://www.iso.org/standard/64774.html
3. **ISTQB Foundation Level Syllabus 2018**
   https://www.istqb.org/certifications/foundation-level
4. **ISTQB glossary of testing terms**
   https://glossary.istqb.org
5. **OWASP Top 10 (2021)**
   https://owasp.org/www-project-top-ten/
6. **OWASP Testing Guide**
   https://owasp.org/www-project-web-security-testing-guide/
7. **OWASP XSS Prevention Cheat Sheet**
   https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
8. **OWASP Broken Access Control (IDOR)**
   https://owasp.org/Top10/A01_2021-Broken_Access_Control/
9. **OWASP Mass Assignment / Over-posting**
   https://owasp.org/www-community/attacks/Mass_assignment
10. **OWASP SQL Injection Prevention Cheat Sheet**
    https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
11. **OWASP Authentication Cheat Sheet**
    https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
12. **OWASP Session Management Cheat Sheet**
    https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
13. **OWASP API Security Top 10 (2023)**
    https://owasp.org/API-Security/editions/2023/en/0x11-t10/
14. **CWE-639: Authorization Bypass Through User-Controlled Key (IDOR)**
    https://cwe.mitre.org/data/definitions/639.html
15. **CWE-79: Cross-site Scripting**
    https://cwe.mitre.org/data/definitions/79.html
16. **CWE-862: Missing Authorization**
    https://cwe.mitre.org/data/definitions/862.html
17. **CWE-863: Incorrect Authorization**
    https://cwe.mitre.org/data/definitions/863.html
18. **W3C Web Content Accessibility Guidelines (WCAG) 2.1**
    https://www.w3.org/TR/WCAG21/
19. **W3C Web Accessibility Tutorials**
    https://www.w3.org/WAI/tutorials/
20. **Mozilla MDN — CORS**
    https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS
21. **Mozilla MDN — HTTP security headers**
    https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers
22. **Mozilla MDN — Web Storage API**
    https://developer.mozilla.org/en-US/docs/Web/API/Web_Storage_API
23. **Mozilla MDN — Responsive design**
    https://developer.mozilla.org/en-US/docs/Learn/CSS/CSS_layout/Responsive_Design
24. **JWT.io — Introduction to JSON Web Tokens**
    https://jwt.io/introduction
25. **RFC 7519 — JSON Web Token (JWT)**
    https://tools.ietf.org/html/rfc7519
26. **Microsoft Learn — REST API design best practices**
    https://learn.microsoft.com/en-us/azure/architecture/best-practices/api-design
27. **Sequelize documentation — Validations**
    https://sequelize.org/docs/v6/core-concepts/validations/
28. **Sequelize dialect-specific things (SQLite/Postgres)**
    https://sequelize.org/docs/v6/other-topics/dialect-specific-things/
29. **Express.js security best practices**
    https://expressjs.com/en/advanced/best-practice-security.html

30. **Helmet.js**
https://helmetjs.github.io/
31. **express-rate-limit**
https://github.com/express-rate-limit/express-rate-limit
32. **Playwright documentation**
https://playwright.dev/docs/intro
33. **Python requests documentation**
https://requests.readthedocs.io/
34. **Karl Wiegers — Writing effective defect reports**
https://www.processimpact.com/articles/bug_report.html
35. **James Bach — Session-based exploratory testing**
https://www.satisfice.com/blog/archives/278
36. **Michael Bolton — The oracle problem**
https://www.developsense.com/blog/2009/08/the-oracle-problem/
37. **IEEE 829 Test Documentation standard (reference)**
https://standards.ieee.org/ieee/829/4317/
38. **ISTQB Defect / Defect lifecycle**
https://glossary.istqb.org/en_US/defect
39. **Google developers — Speed / PageSpeed Insights**
https://developers.google.com/speed
40. **web.dev — Best Practices**
https://web.dev/learn/
41. **Can I use**
https://caniuse.com/
42. **Caddy documentation**
https://caddyserver.com/docs/
43. **PM2 documentation**
https://pm2.keymetrics.io/docs/usage/quick-start/
44. **React documentation**
https://react.dev/learn/managing-state
45. **Vite documentation — env variables**
https://vitejs.dev/guide/env-and-mode.html
46. **React Router documentation**
https://reactrouter.com/home
47. **NIST SP 800-63B password guidelines**
https://pages.nist.gov/800-63-3/sp800-63b.html
48. **CampusPool live deployment**
https://carpool.33.jugaar.ai
49. **CampusPool API health**
https://carpool.33.jugaar.ai/api/health
50. **CampusPool source (local repo README)**
file:///root/campuspool/README.md
51. **CampusPool DEPLOYMENT guide (local)**
file:///root/campuspool/DEPLOYMENT.md
52. **Course defect-report format reference (Lewis-style)**
https://www.processimpact.com/articles/bug_report.html

Appendix E — Testing Methodology Summary

E.1 Approach

1. **Reconnaissance:** Mapped application stack, routes, API surface, deploy topology, demo accounts.
2. **Test design:** Selected techniques (100+) from ISTQB/ISO 25010 practice covering functional, NFR and security dimensions; designed equivalence partitions and boundary values for seats, price, ratings, passwords, limits.
3. **Execution phase 1 — API/security:** Scripted HTTP campaigns against production API; captured status codes and JSON bodies as evidence.
4. **Execution phase 2 — UI:** Playwright journeys for register/login/search/ride/booking/profile/mock pages; screenshots for UI defects; responsive matrix; a11y DOM audit; cross-browser render checks.
5. **Execution phase 3 — white-box:** Reviewed controllers/models/middleware/configs to confirm root causes (mass assignment, sync force:true, missing rate limits, fake payments, etc.).
6. **Defect curation:** Filtered false positives (correct rejections), assigned severity/priority, oracle and impact; produced Lewis-style one-page reports.
7. **Reporting:** Assembled HTML report and converted to print-ready PDF for submission.

E.2 Severity Scale Used

Severity	Definition Used in this Report
Critical	Data loss, complete workflow failure, or financial trust break — release blocking
High	Serious functional/security defect harming users, privacy, or business data
Medium	Functional/QA defect that misleads users or hides failures; fix in current/next iteration
Low	Minor usability/config/doc defect; backlog

E.3 Oracle (Expected Result) Sources

- Application README feature claims and UI copy
- REST/HTTP best practices and status-code semantics
- Security standards (OWASP, CWE) for authz, XSS, PII, rate limiting
- Business rules visible in source (own-ride ban, seat min/max, status enums)
- Common UX expectations (validation messages, dead-link handling, mobile overflow)

E.4 Evidence Pack

- Screenshots: /root/qa-report/evidence/screenshots/ (embedded in this PDF where applicable)
- API evidence: /root/qa-report/evidence/api/session_part*.json
- UI findings: /root/qa-report/evidence/ui/ui_findings.json
- Curated defect list: /root/qa-report/evidence/final_bugs.json

E.5 Limitations

- Testing performed on live demo deployment; backend restart wipes database (noted as Critical defect CR/API-094).
- Payment gateway is simulated — real JazzCash/EasyPaisa/bank flows could not be tested end-to-end.
- Only Chromium/Firefox/WebKit engines available in test host; native iOS/Android devices not physically tested (mobile emulation used instead).
- Email/OTP flows do not exist in the product, so outbound notification testing was not possible.

Tester: Tehzeeb
B23110106073
University of Karachi

Course Head: Hussain Saleem
SQET/ST (Software Quality Engineering & Testing)
8 October 2026

— End of Report —